

GDPR compliance report

Generated: 2026-05-02 23:42:40

Halted (P1): False

Overall score: 28%

Critical / Warning / Info: 14 / 25 / 1

Documents

- ../data/testing_files/md_files_post_gdpr/test4_zoho.md

Chapter scores

Chapter	Score
Ch.2 – Principles	28%
Ch.3 – Rights of data subjects	24%
Ch.4 – Controller & processor	23%
Ch.5 – Transfers to third countries	44%
Ch.8 – Remedies, liability & penalties	100%
Ch.9 – Specific processing situations	52%

Top urgent gaps

- Art. 5 (Principles relating to processing): Accountability
- Art. 6 (Lawfulness of processing): Lawful basis for processing is not stated for all processing activities.
- Art. 7 (Conditions for consent): The policy does not explicitly state that consent requests must be distinguishable from other matters, use clear and plain language, or be presented in an intelligible and easily accessible form.

Scorecard

Art.	Chapter	Title	P	Score	Severity	Status
5	Ch.2 – Principles	Principles relating to processing	p2	10	warning	partial
6	Ch.2 – Principles	Lawfulness of processing	p2	0	critical	fail
7	Ch.2 – Principles	Conditions for consent	p2	28	warning	partial
8	Ch.2 – Principles	Child's consent	p3	70	warning	present (unverified)
9	Ch.2 – Principles	Special category data	p2	44	warning	partial
10	Ch.2 – Principles	Criminal convictions data	p3	0	critical	missing
11	Ch.2 – Principles	Processing without identification	p2	44	warning	partial
12	Ch.3 – Rights of data su	Transparency & modalities	p2	0	critical	fail
13	Ch.3 – Rights of data su	Info collected from data subject	p2	10	warning	partial
14	Ch.3 – Rights of data su	Info not obtained from data subject	p2	10	warning	partial
15	Ch.3 – Rights of data su	Right of access	p2	28	warning	partial
16	Ch.3 – Rights of data su	Right to rectification	p2	52	warning	partial
17	Ch.3 – Rights of data su	Right to erasure	p2	36	warning	partial
18	Ch.3 – Rights of data su	Right to restriction	p2	52	warning	partial
19	Ch.3 – Rights of data su	Notification on rectification/erasure	p3	0	critical	missing
20	Ch.3 – Rights of data su	Right to data portability	p2	44	warning	partial
21	Ch.3 – Rights of data su	Right to object	p2	0	critical	fail
22	Ch.3 – Rights of data su	Automated decision-making	p2	36	warning	partial
24	Ch.4 – Controller & proc	Responsibility of the controller	p2	36	warning	partial
25	Ch.4 – Controller & proc	Privacy by design and default	p3	0	critical	missing
26	Ch.4 – Controller & proc	Joint controllers	p3	0	critical	missing
27	Ch.4 – Controller & proc	Representatives (non-EU)	p3	0	critical	missing
28	Ch.4 – Controller & proc	Processor / DPA	p2	28	warning	partial
29	Ch.4 – Controller & proc	Processing under authority	p2	52	warning	partial
30	Ch.4 – Controller & proc	Records of processing (ROPA)	p2	10	warning	partial
32	Ch.4 – Controller & proc	Security of processing	p3	70	warning	present (unverified)
33	Ch.4 – Controller & proc	Breach notification to SA	p3	0	critical	missing
34	Ch.4 – Controller & proc	Breach communication to data subject	p3	0	critical	missing
35	Ch.4 – Controller & proc	DPIA	p3	0	critical	missing
37	Ch.4 – Controller & proc	DPO designation	p2	44	warning	partial
38	Ch.4 – Controller & proc	DPO position	p3	70	warning	present (unverified)
39	Ch.4 – Controller & proc	DPO tasks	p2	52	warning	partial
40	Ch.4 – Controller & proc	Codes of conduct	p3	0	critical	missing
42	Ch.4 – Controller & proc	Certification	p3	0	critical	missing
44	Ch.5 – Transfers to thir	General principle for transfers	p2	52	warning	partial
45	Ch.5 – Transfers to thir	Adequacy decision transfers	p2	52	warning	partial
46	Ch.5 – Transfers to thir	Transfers with safeguards	p3	70	warning	present (unverified)
47	Ch.5 – Transfers to thir	Binding corporate rules	p3	0	critical	missing
77	Ch.8 – Remedies, liabili	Right to lodge a complaint	p2	100	info	pass
88	Ch.9 – Specific processi	Employment context	p2	52	warning	partial

Scope (Art.2/3) + pipeline summary (raw JSON)

```
{
```

```

"scope": {
  "applies": "yes",
  "reasons": [
    "The policy describes collection of personal data (name, contact number, email address, company name, country, photo, time zone, language, username, password, security question and answer) in the context of account signup for services.",
    "This falls under 'processing of personal data' as defined in Art. 2 (Material scope).",
    "The policy mentions collection of information when users 'sign up for an account to access one or more of our services', which implies an establishment within the Union or targeting of individuals in the Union, satisfying Art. 3 (Territorial scope).",
    "The company's domain 'zoho.com' is often associated with global services, and the policy details specific data collection practices that are typical of online service providers, suggesting potential applicability to individuals within the EU."
  ],
  "evidence": [
    "When you sign up for an account to access one or more of our services, we ask for information like your name, contact number, email address, company name and country to complete the account signup process.",
    "This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.",
    "This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to: the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union;"
  ],
  "hil_required": false
},
"pipeline_summary": {
  "overall_score_pct": 46,
  "p2_score": 0.46,
  "p2_findings_total": 25,
  "p3_findings_total": 15,
  "p4_triggered_total": 0,
  "p4_articles_not_triggered": 6,
  "findings_total": 40,
  "hil_queue_total": 15
},
"computed_scoring": {
  "overall_score_pct": 28,
  "chapter_scores": {
    "Ch.2 - Principles": 28,
    "Ch.3 - Rights of data subjects": 24,
    "Ch.4 - Controller & processor": 23,
    "Ch.5 - Transfers to third countries": 44,
    "Ch.8 - Remedies, liability & penalties": 100,
    "Ch.9 - Specific processing situations": 52
  },
  "severity_counts": {
    "critical": 14,
    "warning": 25,
    "info": 1
  }
}
}

```

Appendix — finding detail

Art. 5 — Principles relating to processing

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 10/100

Risk: medium

Gaps

- Accountability
- Lawfulness, fairness and transparency
- Purpose limitation
- Data minimisation
- Accuracy
- Storage limitation
- Integrity and confidentiality

Evidence

- We collect information about you only if we need the information for some legitimate purpose.

Notes

The policy covers several principles of GDPR Article 5, including purpose limitation (collecting information for a legitimate purpose), data minimisation (asking only for necessary information for sign-up, and offering optional additional information), and accuracy (storing the last four digits of credit card numbers and not the full number). However, there are gaps in explicitly addressing lawfulness, fairness, transparency, and accountability. The policy also does not clearly state how long data is stored (storage limitation) or how it is secured (integrity and confidentiality).

```
{
  "article_number": 5,
  "article_title": "Principles relating to processing",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Accountability",
    "Lawfulness, fairness and transparency",
    "Purpose limitation",
    "Data minimisation",
    "Accuracy",
    "Storage limitation",
    "Integrity and confidentiality"
  ],
  "evidence": [
    "We collect information about you only if we need the information for some legitimate purpose."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy covers several principles of GDPR Article 5, including purpose limitation (collecting information for a legitimate purpose), data minimisation (asking only for necessary information for sign-up, and offering optional additional information), and accuracy (storing the last four digits of credit card numbers and not the full number). However, there are gaps in explicitly addressing lawfulness, fairness, transparency, and accountability. The policy also does not clearly state how long data is stored (storage limitation) or how it is secured (integrity and confidentiality).",
  "article_material_used": "text"
}
```

Art. 6 — Lawfulness of processing

Priority: p2 Chapter: Ch.2 – Principles

Severity: critical Status: fail

Score: 0/100

Risk: critical

Gaps

- Lawful basis for processing is not stated for all processing activities.

Notes

The policy mentions collecting information for 'legitimate purpose' but does not specify the lawful basis (e.g., consent, contract, legitimate interest) for each processing activity as required by GDPR Article 6.

```
{
  "article_number": 6,
  "article_title": "Lawfulness of processing",
  "chapter": "Ch.2 - Principles",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "Lawful basis for processing is not stated for all processing activities."
  ],
  "evidence": [],
  "risk": "critical",
  "needs_human_review": false,
  "notes": "The policy mentions collecting information for 'legitimate purpose' but does not specify the lawful basis (e.g., consent, contract, legitimate interest) for each processing activity as required by GDPR Article 6.",
  "article_material_used": "text"
}
```

Art. 7 — Conditions for consent

Priority: p2 Chapter: Ch.2 – Principles

Severity: warning Status: partial

Score: 28/100

Risk: medium

Gaps

- The policy does not explicitly state that consent requests must be distinguishable from other matters, use clear and plain language, or be presented in an intelligible and easily accessible form.
- The policy does not explicitly state that consent must be freely given, and it does not detail any specific mechanisms to ensure this, for instance, by avoiding making contract performance conditional on consent for unnecessary processing.
- The policy does not explicitly state that consent must be specific, and it does not detail how specificity is ensured for different processing purposes.
- The policy does not explicitly state that consent must be informed, and it does not detail what information is provided to the data subject prior to obtaining consent.

Evidence

- You can disable browser cookies before visiting our websites.
- You can also delete or change your optional profile information.

Notes

The policy mentions the right to withdraw consent and provides some examples of opting out or choosing not to provide certain information. However, it does not explicitly cover all aspects of Article 7, such as consent being freely given, specific, informed, and unambiguous, nor does it detail the presentation of consent requests in a distinguishable and easily accessible manner.

```
{
  "article_number": 7,
  "article_title": "Conditions for consent",
  "chapter": "Ch.2 - Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that consent requests must be distinguishable from other matters, use clear and plain language, or be presented in an intelligible and easily accessible form.",
    "The policy does not explicitly state that consent must be freely given, and it does not detail any specific mechanisms to ensure this, for instance, by avoiding making contract performance conditional on consent for unnecessary processing.",
    "The policy does not explicitly state that consent must be specific, and it does not detail how specificity is ensured for different processing purposes.",
    "The policy does not explicitly state that consent must be informed, and it does not detail what information is provided to the data subject prior to obtaining consent."
  ],
  "evidence": [
    "You can disable browser cookies before visiting our websites.",
    "You can also delete or change your optional profile information."
  ]
}
```

```

    ],
    "risk": "medium",
    "needs_human_review": false,
    "notes": "The policy mentions the right to withdraw consent and provides some examples of
    opting out or choosing not to provide certain information. However, it does not explicitly
    cover all aspects of Article 7, such as consent being freely given, specific, informed, and
    unambiguous, nor does it detail the presentation of consent requests in a distinguishable and
    easily accessible manner.",
    "article_material_used": "text"
  }

```

Art. 8 — Child's consent

Priority: p3 Chapter: Ch.2 – Principles
 Severity: warning Status: present (unverified)
 Score: 70/100

```

{
  "article_number": 8,
  "article_title": "Child's consent",
  "chapter": "Ch.2 – Principles",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": [],
  "notes": null,
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 9 — Special category data

Priority: p2 Chapter: Ch.2 – Principles
 Severity: warning Status: partial
 Score: 44/100
 Risk: high
 Gaps

- Policy does not explicitly state how sensitive data keywords (health, biometric, racial, religious) are handled.
- Policy does not mention requirements for explicit consent or Art.9(2) derogations when processing special category data.

Notes

The policy does not contain any information regarding the processing of special category data as defined in GDPR Article 9. There is no mention of keywords related to sensitive data, nor any procedures for obtaining explicit consent or relying on derogations for processing such data.

```

{
  "article_number": 9,
  "article_title": "Special category data",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Policy does not explicitly state how sensitive data keywords (health, biometric, racial,
    religious) are handled.",
    "Policy does not mention requirements for explicit consent or Art.9(2) derogations when
    processing special category data."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy does not contain any information regarding the processing of special
  category data as defined in GDPR Article 9. There is no mention of keywords related to
  sensitive data, nor any procedures for obtaining explicit consent or relying on derogations for
  processing such data.",
  "article_material_used": "text"
}

```

Art. 10 — Criminal convictions data

Priority: p3 Chapter: Ch.2 – Principles

Severity: critical Status: missing
Score: 0/100
Notes

The policy does not mention criminal convictions data or data relating to criminal offenses. It discusses the types of personal data collected, how it is used, and with whom it is shared, but there is no specific mention of Article 10 data.

```
{
  "article_number": 10,
  "article_title": "Criminal convictions data",
  "chapter": "Ch.2 – Principles",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not mention criminal convictions data or data relating to criminal offenses. It discusses the types of personal data collected, how it is used, and with whom it is shared, but there is no specific mention of Article 10 data.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 11 — Processing without identification

Priority: p2 Chapter: Ch.2 – Principles
Severity: warning Status: partial
Score: 44/100
Risk: medium
Gaps

- The policy does not explicitly state whether processing is done without identification, nor does it detail specific measures for anonymisation or pseudonymisation in line with Article 11 requirements.
- There is no information provided on how the company handles situations where data subjects cannot be identified, or the implications for Articles 15-20 in such cases.

Notes

The policy mentions collecting information 'only if we need the information for some legitimate purpose', which aligns with data minimisation principles. However, it does not provide specific details on processing data without identification as required by Article 11. Therefore, compliance cannot be fully assessed.

```
{
  "article_number": 11,
  "article_title": "Processing without identification",
  "chapter": "Ch.2 – Principles",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state whether processing is done without identification, nor does it detail specific measures for anonymisation or pseudonymisation in line with Article 11 requirements.",
    "There is no information provided on how the company handles situations where data subjects cannot be identified, or the implications for Articles 15-20 in such cases."
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy mentions collecting information 'only if we need the information for some legitimate purpose', which aligns with data minimisation principles. However, it does not provide specific details on processing data without identification as required by Article 11. Therefore, compliance cannot be fully assessed.",
  "article_material_used": "text"
}
```

Art. 12 — Transparency & modalities

Priority: p2 Chapter: Ch.3 – Rights of data subjects
Severity: critical Status: fail
Score: 0/100
Risk: high

Gaps

- The policy does not specify a timeframe for responding to data subject requests, which should ideally be within one month, with a possible extension.
- The policy does not explicitly state that information or actions taken regarding data subject requests will be provided free of charge, except in cases of unfounded or excessive requests.

Evidence

- You have the right to update the information we hold about you or to rectify any inaccuracies.

Notes

The policy outlines several data subject rights (access, rectification, deletion, restriction, portability, objection) but lacks crucial details regarding the response timeframe and the 'free of charge' principle as required by GDPR Article 12(3) and 12(5). The policy does not mention the commitment to respond within one month (or the extension process), nor does it confirm that responses will be free of charge unless requests are manifestly unfounded or excessive.

```
{
  "article_number": 12,
  "article_title": "Transparency & modalities",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not specify a timeframe for responding to data subject requests, which should ideally be within one month, with a possible extension.",
    "The policy does not explicitly state that information or actions taken regarding data subject requests will be provided free of charge, except in cases of unfounded or excessive requests."
  ],
  "evidence": [
    "You have the right to update the information we hold about you or to rectify any inaccuracies."
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy outlines several data subject rights (access, rectification, deletion, restriction, portability, objection) but lacks crucial details regarding the response timeframe and the 'free of charge' principle as required by GDPR Article 12(3) and 12(5). The policy does not mention the commitment to respond within one month (or the extension process), nor does it confirm that responses will be free of charge unless requests are manifestly unfounded or excessive.",
  "article_material_used": "text"
}
```

Art. 13 — Info collected from data subject

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 10/100

Risk: medium

Gaps

- Controller identity and contact details
- Data Protection Officer contact details (if applicable)
- Purposes of the processing and legal basis
- Legitimate interests pursued (if applicable)
- Recipients or categories of recipients
- Data transfer to third countries/international organisations (if applicable)
- Storage period or criteria for determining it
- Data subject rights (access, rectification, erasure, restriction, objection, portability)

Evidence

- We collect information about you only if we need the information for some legitimate purpose.

Notes

The policy provides some information regarding the types of data collected, the purposes of processing (e.g., account signup, event registration, purchases, testimonials, website analytics, service improvement), and the sources of data (provided by user, automatically collected, from third parties). However, it lacks specific details required by Article 13, such as controller identity and contact details, DPO contact details (if applicable), explicit

legal bases for each processing activity, the retention period or criteria for it, a comprehensive list of recipients, details on international transfers, and a clear summary of data subject rights. The information on automated decision-making and profiling is also missing.

```
{
  "article_number": 13,
  "article_title": "Info collected from data subject",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Controller identity and contact details",
    "Data Protection Officer contact details (if applicable)",
    "Purposes of the processing and legal basis",
    "Legitimate interests pursued (if applicable)",
    "Recipients or categories of recipients",
    "Data transfer to third countries/international organisations (if applicable)",
    "Storage period or criteria for determining it",
    "Data subject rights (access, rectification, erasure, restriction, objection, portability)",
    "Right to withdraw consent (if consent is the legal basis)",
    "Right to lodge a complaint with a supervisory authority",
    "Statutory or contractual requirement to provide data and consequences of failure",
    "Existence and logic of automated decision-making, including profiling (if applicable)"
  ],
  "evidence": [
    "We collect information about you only if we need the information for some legitimate purpose."
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy provides some information regarding the types of data collected, the purposes of processing (e.g., account signup, event registration, purchases, testimonials, website analytics, service improvement), and the sources of data (provided by user, automatically collected, from third parties). However, it lacks specific details required by Article 13, such as controller identity and contact details, DPO contact details (if applicable), explicit legal bases for each processing activity, the retention period or criteria for it, a comprehensive list of recipients, details on international transfers, and a clear summary of data subject rights. The information on automated decision-making and profiling is also missing.",
  "article_material_used": "text"
}
```

Art. 14 — Info not obtained from data subject

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 10/100

Risk: high

Gaps

- Article 14(1)(a): Identity and contact details of the controller.
- Article 14(1)(b): Contact details of the data protection officer, where applicable.
- Article 14(1)(c): Purposes of the processing and legal basis.
- Article 14(1)(d): Categories of personal data.
- Article 14(1)(e): Recipients or categories of recipients.
- Article 14(1)(f): Transfer of personal data to third countries or international organisations.
- Article 14(2)(a): Period for which the personal data will be stored or criteria used to determine that period.
- Article 14(2)(b): Legitimate interests pursued by the controller or by a third party, where processing is based on point (f) of Article 6(1).

Notes

The policy states that Zoho obtains information from third parties, which triggers the requirements of Article 14. However, the policy does not provide details on the specific information required by Article 14(1) and Article 14(2), such as the identity and contact details of the controller, DPO contact details, purposes and legal basis of processing, categories of data, recipients, data transfer details, storage periods, legitimate interests, data subject rights (access, rectification, erasure, restriction, objection, portability), right to withdraw consent, right to lodge a complaint, source of data, and details on automated decision-making and profiling. The timing of when this information is provided is also not specified.

```
{
  "article_number": 14,
  "article_title": "Info not obtained from data subject",
}
```

```

"chapter": "Ch.3 - Rights of data subjects",
"priority": "p2",
"status": "partial",
"gaps": [
  "Article 14(1)(a): Identity and contact details of the controller.",
  "Article 14(1)(b): Contact details of the data protection officer, where applicable.",
  "Article 14(1)(c): Purposes of the processing and legal basis.",
  "Article 14(1)(d): Categories of personal data.",
  "Article 14(1)(e): Recipients or categories of recipients.",
  "Article 14(1)(f): Transfer of personal data to third countries or international
organisations.",
  "Article 14(2)(a): Period for which the personal data will be stored or criteria used to
determine that period.",
  "Article 14(2)(b): Legitimate interests pursued by the controller or by a third party,
where processing is based on point (f) of Article 6(1).",
  "Article 14(2)(c): Existence of the right to request access, rectification, erasure,
restriction of processing, and the right to object and data portability.",
  "Article 14(2)(d): Existence of the right to withdraw consent, where processing is based on
point (a) of Article 6(1) or point (a) of Article 9(2).",
  "Article 14(2)(e): Right to lodge a complaint with a supervisory authority.",
  "Article 14(2)(f): Source of the personal data and whether it came from publicly accessible
sources.",
  "Article 14(2)(g): Existence of automated decision-making, including profiling, and
meaningful information about the logic involved, significance, and envisaged consequences.",
  "Article 14(3): Timing of provision of information."
],
"evidence": [],
"risk": "high",
"needs_human_review": false,
"notes": "The policy states that Zoho obtains information from third parties, which triggers
the requirements of Article 14. However, the policy does not provide details on the specific
information required by Article 14(1) and Article 14(2), such as the identity and contact
details of the controller, DPO contact details, purposes and legal basis of processing,
categories of data, recipients, data transfer details, storage periods, legitimate interests,
data subject rights (access, rectification, erasure, restriction, objection, portability),
right to withdraw consent, right to lodge a complaint, source of data, and details on automated
decision-making and profiling. The timing of when this information is provided is also not
specified.",
"article_material_used": "text"
}

```

Art. 15 — Right of access

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 28/100

Risk: medium

Gaps:

- Policy does not mention the process for submitting a SAR.
- Policy does not specify the timeline for responding to a SAR.
- Policy does not detail the identity verification process for SARs.
- Policy does not state what specific information is provided as part of a SAR response.

Notes:

The policy states that data subjects have the right to access their personal information and obtain a copy. However, it does not provide details on how to submit a Subject Access Request (SAR), the timeframe for response, the identity verification process, or what specific information will be provided in the response. This constitutes a partial compliance.

```

{
  "article_number": 15,
  "article_title": "Right of access",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "Policy does not mention the process for submitting a SAR.",
    "Policy does not specify the timeline for responding to a SAR.",
    "Policy does not detail the identity verification process for SARs.",
    "Policy does not state what specific information is provided as part of a SAR response."
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy states that data subjects have the right to access their personal
information and obtain a copy. However, it does not provide details on how to submit a Subject

```

```

Access Request (SAR), the timeframe for response, the identity verification process, or what
specific information will be provided in the response. This constitutes a partial compliance.",
  "article_material_used": "text"
}

```

Art. 16 — Right to rectification

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 52/100

Risk: medium

Gaps

- The policy does not specify that rectification must occur 'without undue delay'.

Notes

The policy confirms the right to rectify inaccuracies, but does not include the 'without undue delay' timeframe.

```

{
  "article_number": 16,
  "article_title": "Right to rectification",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not specify that rectification must occur 'without undue delay'."
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy confirms the right to rectify inaccuracies, but does not include the
'without undue delay' timeframe.",
  "article_material_used": "text"
}

```

Art. 17 — Right to erasure

Priority: p2 **Chapter:** Ch.3 – Rights of data subjects

Severity: warning **Status:** partial

Score: 36/100

Risk: medium

Gaps

- The policy does not describe the process for handling deletion requests.
- The policy does not detail the grounds for refusing a deletion request.
- The policy does not specify any retention exceptions that might override the right to erasure.

Notes

The policy acknowledges the right to request deletion of personal information under certain circumstances, specifically when the data is no longer necessary for its original purpose. However, it does not outline the specific process for submitting such a request, the criteria for refusing a request, or any exceptions to the erasure right (e.g., legal obligations, public interest, or defense of legal claims). This lack of detail presents a risk.

```

{
  "article_number": 17,
  "article_title": "Right to erasure",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not describe the process for handling deletion requests.",
    "The policy does not detail the grounds for refusing a deletion request.",
    "The policy does not specify any retention exceptions that might override the right to
erasure."
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy acknowledges the right to request deletion of personal information under
certain circumstances, specifically when the data is no longer necessary for its original
purpose. However, it does not outline the specific process for submitting such a request, the
criteria for refusing a request, or any exceptions to the erasure right (e.g., legal
obligations, public interest, or defense of legal claims). This lack of detail presents a risk."
}

```

```
"",
  "article_material_used": "text"
}
```

Art. 18 — Right to restriction

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 52/100

Risk: medium

Gaps

- The policy does not explicitly state the conditions under which a data subject can request a restriction of processing (e.g., accuracy contested, unlawful processing, data no longer needed but required for legal claims, or objection pending verification of legitimate grounds).

Notes

The policy mentions the right to restrict the use of information in a specific circumstance (objection pending verification of legitimate grounds), but it does not cover all conditions outlined in GDPR Article 18(1). Therefore, the compliance is partial.

```
{
  "article_number": 18,
  "article_title": "Right to restriction",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state the conditions under which a data subject can request a restriction of processing (e.g., accuracy contested, unlawful processing, data no longer needed but required for legal claims, or objection pending verification of legitimate grounds).",
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy mentions the right to restrict the use of information in a specific circumstance (objection pending verification of legitimate grounds), but it does not cover all conditions outlined in GDPR Article 18(1). Therefore, the compliance is partial.",
  "article_material_used": "text"
}
```

Art. 19 — Notification on rectification/erasure

Priority: p3 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: missing

Score: 0/100

Notes

The policy does not mention notification to recipients in the event of rectification or erasure of data.

```
{
  "article_number": 19,
  "article_title": "Notification on rectification/erasure",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not mention notification to recipients in the event of rectification or erasure of data.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 20 — Right to data portability

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 44/100

Risk: medium

Gaps

- The policy mentions the right to transfer information to a third party in a structured, commonly used and machine-readable format, but does not specify that this applies when the information is processed with consent or by automated means.
- The policy does not explicitly mention the right to transmit data to another controller without hindrance, nor the controller-to-controller transfer right.

Notes

The policy mentions the right to data portability in a structured, commonly used and machine-readable format, but it lacks explicit details on the controller-to-controller transfer right and the conditions (consent or automated means) under which this right applies.

```
{
  "article_number": 20,
  "article_title": "Right to data portability",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy mentions the right to transfer information to a third party in a structured, commonly used and machine-readable format, but does not specify that this applies when the information is processed with consent or by automated means.",
    "The policy does not explicitly mention the right to transmit data to another controller without hindrance, nor the controller-to-controller transfer right."
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy mentions the right to data portability in a structured, commonly used and machine-readable format, but it lacks explicit details on the controller-to-controller transfer right and the conditions (consent or automated means) under which this right applies.",
  "article_material_used": "text"
}
```

Art. 21 — Right to object

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: critical Status: fail

Score: 0/100

Risk: high

Gaps

- The policy does not explicitly mention how individuals can object to direct marketing or profiling.
- The policy does not state that the right to object must be brought to the attention of the data subject at the latest at the time of the first communication.
- The policy does not specify if data subjects can exercise their right to object using automated means.
- The policy does not describe the process for opting out of direct marketing or profiling.

Notes

The policy does not provide any information about the right to object to direct marketing or profiling, nor does it mention how this right can be exercised by the data subject. There is no information on whether automated means can be used to exercise this right. Therefore, compliance with Article 21 cannot be confirmed.

```
{
  "article_number": 21,
  "article_title": "Right to object",
  "chapter": "Ch.3 – Rights of data subjects",
  "priority": "p2",
  "status": "fail",
  "gaps": [
    "The policy does not explicitly mention how individuals can object to direct marketing or profiling.",
    "The policy does not state that the right to object must be brought to the attention of the data subject at the latest at the time of the first communication.",
    "The policy does not specify if data subjects can exercise their right to object using automated means.",
    "The policy does not describe the process for opting out of direct marketing or profiling."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy does not provide any information about the right to object to direct marketing or profiling, nor does it mention how this right can be exercised by the data subject."
}
```

```

There is no information on whether automated means can be used to exercise this right.
Therefore, compliance with Article 21 cannot be confirmed.",
"article_material_used": "text"
}

```

Art. 22 — Automated decision-making

Priority: p2 Chapter: Ch.3 – Rights of data subjects

Severity: warning Status: partial

Score: 36/100

Risk: high

Gaps

- The company policy does not explicitly mention the right not to be subject to automated decision-making, including profiling, which produces legal effects or similarly significantly affects individuals.
- The company policy does not detail the specific measures in place to safeguard data subjects' rights and freedoms in cases where automated decision-making is necessary for contract performance, authorized by law, or based on explicit consent, specifically regarding the right to human intervention, to express a point of view, and to contest the decision.
- The company policy does not address the use of automated decision-making based on special categories of personal data and the necessary safeguarding measures.

Evidence

- hange your optional profile information. You

can always choose not to fill in non-mandatory fields when you submit any form linked to our websites.

All Zoho group entities listed here have access to the information covered in Part I. We do not sell any personal information. We share your information only in the ways that are described in this : Employees and independent contractors of all Zoho group entities have access to the information covered in Part I on a need-to-know basis. We require all employees and independent contractors of Zoho group entities to follow this : We may need to share your personal information and aggregated or de-identified information with third-party service providers that we engage, such as marketing and advertising partners, event organizers, web analytics providers and payment processors. These service providers are authorized to use your personal information only as necessary to provide these services to us. :

When you register a domain through Zoho from domain name registrars, we share your name and contact information such as your physical address, email address and phone number with them as per the ICANN domain registration rules. : We may share y

- domain name registrars, we share your name and contact information such as your physical address, email address and phone number with them as per the ICANN domain registration rules. : We may share your personal information with our authorized reselling partners in your region, solely for the purpose of contacting you about products that you have downloaded or services that you have signed up for. We will give you an option to opt out of continuing to work with that partner. : When you install or purchase any application developed using Zoho's APIs that is posted on Zoho's online marketplace, your name and email address will be shared with the developer of the application, so they may engage with you directly as the provider of that application or service. Zoho does not control the use of your personal information by the developers, which will be based on their own privacy policies. : Other scenarios in which we may share the same information covered under Parts I and II are described in Part III. If you are in the European Economic Area (EEA), you have the following rights with respect to information that Zoho holds about you. Zoho undertakes to

provide you the same rights no ma

- in Part III. If you are in the European Economic Area (EEA), you have the following rights with respect to information that Zoho holds about you. Zoho undertakes to

provide you the same rights no matter where you choose to live. : You have the right to access (and obtain a copy of, if required) the categories of personal information that we hold about you, including the information's source, purpose and period of processing, and the persons to whom the information is shared : You have the right to update the information we hold about you or to rectify any inaccuracies.

Based on the purpose for which we use your information, you can instruct us to add supplemental information about you in our database. : You have the right to request that we delete your personal information in certain circumstances, such as when it is no longer necessary for the purpose for which it was originally collected. : You may also have the right to request to restrict the use of your information in certain circumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it. : You have the right to transfer your information to

- rcumstances, such as when you have objected to our use of your data but we need to verify whether we have overriding legitimate grounds to use it. : You have the right to transfer your information to a third party in a structured, commonly used and machine-readable format, in circumstances where the information is processed with your consent or by automated means. : You have the right to object to the use of your information in certain circumstances, such as the use of your personal information for direct marketing. : You have the right to complain to the appropriate supervisory authority if you have any grievance against the way we collect, use or share your information. This right may not be available to you if there is no supervisory authority dealing with data protection in your country. We retain your personal information for as long as it is required for the purposes stated in this : You may entrust information that you or your organization ("you") control, to Zoho in connection with use of our services or for requesting technical support for our products. This includes information regarding yo

Notes

The policy mentions the right to withdraw consent and opt-out options for specific communications, but it does not directly address the right not to be subject to solely automated decisions, including profiling, that have legal or significant effects. Additionally, there is no mention of specific safeguards or the right to human intervention, a point of view, or contesting decisions related to automated processing. The policy also lacks information on automated decision-making concerning special categories of data.

```
{
  "article_number": 22,
  "article_title": "Automated decision-making",
  "chapter": "Ch.3 - Rights of data subjects",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The company policy does not explicitly mention the right not to be subject to automated decision-making, including profiling, which produces legal effects or similarly significantly affects individuals.",
    "The company policy does not detail the specific measures in place to safeguard data subjects' rights and freedoms in cases where automated decision-making is necessary for contract performance, authorized by law, or based on explicit consent, specifically regarding the right to human intervention, to express a point of view, and to contest the decision.",
    "The company policy does not address the use of automated decision-making based on special categories of personal data and the necessary safeguarding measures."
  ],
  "evidence": [
    "hange your optional profile information. You\ncan always choose not to fill in non-mandatory fields when you submit any form linked to our websites.\nAll Zoho group entities listed here have access to the information covered in Part I. We do not sell any\npersonal information. We share your information only in the ways that are described in this : Employees\ and independent contractors of all Zoho group entities have access to the information covered in Part I\non a need-to-know basis. We require all employees and independent contractors of Zoho group entities\nto follow this : We may need to share your personal information and aggregated or de-identified\ninformation with third-party service providers that we engage, such as marketing and advertising\npartners, event organizers, web analytics providers and payment processors. These service providers\nare authorized to use your personal information only as necessary to provide these services to us. :\nWhen you register a domain through Zoho from domain name registrars, we share your name and\ncontact information such as your physical address, email address and phone number with them as per\nthe ICANN domain registration rules. : We may share y",
    "domain name registrars, we share your name and\ncontact information such as your physical address, email address and phone number with them as per\nthe ICANN domain registration rules. : We may share your personal information with our authorized\nreselling partners in your region, solely for the purpose of contacting you about products that you have\ndownloaded or services that you have signed up for. We will give you an option to opt out of continuing\nto work with that partner. : When you install or purchase any application developed using Zoho's APIs\nthat is posted on Zoho's online marketplace, your name and email address will be shared with the\ndeveloper of the application, so they may engage with you directly as the provider of that application or\nservice. Zoho does not control the use of your personal information by the developers, which will be\nbased on their own privacy policies. : Other scenarios in which we
```

may share the same information\ncovered under Parts I and II are described in Part III. If you are in the European Economic Area (EEA),\nyou have the following rights with respect to information that Zoho holds about you. Zoho undertakes to\n\nprovide you the same rights no ma",
 "in Part III. If you are in the European Economic Area (EEA),\nyou have the following rights with respect to information that Zoho holds about you. Zoho undertakes to\n\nprovide you the same rights no matter where you choose to live. : You have the right to access (and\nobtain a copy of, if required) the categories of personal information that we hold about you, including\nthe information's source, purpose and period of processing, and the persons to whom the information is\nshared : You have the right to update the information we hold about you or to rectify any inaccuracies.\nBased on the purpose for which we use your information, you can instruct us to add supplemental\ninformation about you in our database. : You have the right to request that we delete your personal\ninformation in certain circumstances, such as when it is no longer necessary for the purpose for which it\nwas originally collected. : You may also have the right to request to restrict the use of your information\nin certain circumstances, such as when you have objected to our use of your data but we need to verify\nwhether we have ove
 ... (truncated)

Art. 24 — Responsibility of the controller

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 36/100

Risk: medium

Gaps

- The policy does not explicitly state that the controller implements appropriate technical and organisational measures to ensure and demonstrate compliance with the GDPR.
- The policy does not mention the review and updating of these measures.
- There is no mention of implementing data protection policies, as required by GDPR Article 24(2) when proportionate.

Evidence

- All Zoho group entities listed here have access to t

Notes

The policy mentions sharing data with third parties and internal access on a need-to-know basis, which are aspects of organizational measures. However, it does not explicitly detail the implementation of technical and organizational measures to ensure and demonstrate GDPR compliance, nor does it mention reviewing or updating these measures or implementing data protection policies as required by Article 24.

```
{
  "article_number": 24,
  "article_title": "Responsibility of the controller",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that the controller implements appropriate technical and organisational measures to ensure and demonstrate compliance with the GDPR.",
    "The policy does not mention the review and updating of these measures.",
    "There is no mention of implementing data protection policies, as required by GDPR Article 24(2) when proportionate."
  ],
  "evidence": [
    "All Zoho group entities listed here have access to t"
  ],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy mentions sharing data with third parties and internal access on a need-to-know basis, which are aspects of organizational measures. However, it does not explicitly detail the implementation of technical and organizational measures to ensure and demonstrate GDPR compliance, nor does it mention reviewing or updating these measures or implementing data protection policies as required by Article 24.",
  "article_material_used": "text"
}
```

Art. 25 — Privacy by design and default

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

```
{
  "article_number": 25,
```



```

"article_title": "Privacy by design and default",
"chapter": "Ch.4 – Controller & processor",
"priority": "p3",
"policy_present": false,
"implementation_unverified": false,
"needs_human_review": true,
"evidence": [],
"notes": null,
"status": null,
"gaps": [],
"risk": null
}

```

Art. 26 — Joint controllers

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The policy does not contain any mention of joint controllership or how it is determined or handled.

```

{
  "article_number": 26,
  "article_title": "Joint controllers",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not contain any mention of joint controllership or how it is
determined or handled.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 27 — Representatives (non-EU)

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The policy does not contain any information about non-EU representatives or the requirement for a written mandate.

```

{
  "article_number": 27,
  "article_title": "Representatives (non-EU)",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not contain any information about non-EU representatives or the
requirement for a written mandate.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 28 — Processor / DPA

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 28/100

Risk: medium

Gaps

- The policy does not specify a sub-processor list.
- The policy does not mention audit rights for the controller.

- The policy does not explicitly state the deletion or return obligation of personal data after service termination, other than a general right to request deletion.
- The policy does not explicitly confirm that processing is governed by a contract or legal act that sets out the subject-matter, duration, nature, purpose, data types, data subjects, and obligations/rights of the controller, as required by Article 28(3).

Notes

The policy mentions sharing personal information with third-party service providers and outlines some data subject rights regarding deletion. However, it lacks explicit details on contractual obligations for processors regarding sub-processors, audit rights, and a clear deletion/return obligation post-service. Therefore, compliance is partial.

```
{
  "article_number": 28,
  "article_title": "Processor / DPA",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not specify a sub-processor list.",
    "The policy does not mention audit rights for the controller.",
    "The policy does not explicitly state the deletion or return obligation of personal data after service termination, other than a general right to request deletion.",
    "The policy does not explicitly confirm that processing is governed by a contract or legal act that sets out the subject-matter, duration, nature, purpose, data types, data subjects, and obligations/rights of the controller, as required by Article 28(3).",
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy mentions sharing personal information with third-party service providers and outlines some data subject rights regarding deletion. However, it lacks explicit details on contractual obligations for processors regarding sub-processors, audit rights, and a clear deletion/return obligation post-service. Therefore, compliance is partial.",
  "article_material_used": "text"
}
```

Art. 29 — Processing under authority

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 52/100

Risk: medium

Gaps

- The policy does not specify that the processor and any person acting under the authority of the controller or processor shall not process personal data except on instructions from the controller, unless required to do so by Union or Member State law.

Notes

The policy does not provide any explicit information regarding the requirement for processors and individuals acting under their authority to process personal data only on the instructions of the controller, as mandated by GDPR Article 29. Therefore, it is not possible to verify compliance with this article.

```
{
  "article_number": 29,
  "article_title": "Processing under authority",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not specify that the processor and any person acting under the authority of the controller or processor shall not process personal data except on instructions from the controller, unless required to do so by Union or Member State law.",
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The policy does not provide any explicit information regarding the requirement for processors and individuals acting under their authority to process personal data only on the instructions of the controller, as mandated by GDPR Article 29. Therefore, it is not possible to verify compliance with this article.",
  "article_material_used": "text"
}
```

Art. 30 — Records of processing (ROPA)

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 10/100

Risk: high

Gaps

- The company policy does not explicitly state that a record of processing activities (ROPA) is maintained.
- The policy does not detail the 'purposes of the processing' beyond general statements.
- The policy does not specify 'categories of data subjects' or 'categories of personal data'.
- While recipients are mentioned, the policy does not provide a comprehensive list or categories of 'recipients to whom the personal data have been or will be disclosed'.
- Information regarding 'transfers of personal data to a third country or an international organisation' is not explicitly mentioned.
- The policy does not state 'time limits for erasure of the different categories of data'.
- A 'general description of the technical and organisational security measures' is not provided within the policy.

Evidence

- We share your information only in the ways that are described in this : Employees

Notes

The policy mentions that data subjects have the right to access information about the 'categories of personal information', 'purpose and period of processing', and 'persons to whom the information is shared'. This implies that such information might be recorded, but the policy itself does not explicitly confirm the existence of a ROPA nor does it detail its contents in line with Article 30 requirements. Specifically, details on data subject categories, data categories, comprehensive recipient categories, international transfers, retention periods, and security measures are missing.

```
{
  "article_number": 30,
  "article_title": "Records of processing (ROPA)",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The company policy does not explicitly state that a record of processing activities (ROPA) is maintained.",
    "The policy does not detail the 'purposes of the processing' beyond general statements.",
    "The policy does not specify 'categories of data subjects' or 'categories of personal data'."
  ],
  "While recipients are mentioned, the policy does not provide a comprehensive list or categories of 'recipients to whom the personal data have been or will be disclosed'.",
  "Information regarding 'transfers of personal data to a third country or an international organisation' is not explicitly mentioned.",
  "The policy does not state 'time limits for erasure of the different categories of data'.",
  "A 'general description of the technical and organisational security measures' is not provided within the policy."
  ],
  "evidence": [
    "We share your information only in the ways that are described in this : Employees"
  ],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy mentions that data subjects have the right to access information about the 'categories of personal information', 'purpose and period of processing', and 'persons to whom the information is shared'. This implies that such information might be recorded, but the policy itself does not explicitly confirm the existence of a ROPA nor does it detail its contents in line with Article 30 requirements. Specifically, details on data subject categories, data categories, comprehensive recipient categories, international transfers, retention periods, and security measures are missing.",
  "article_material_used": "text"
}
```

Art. 32 — Security of processing

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: warning Status: present (unverified)

Score: 70/100

Notes

The policy mentions industry certifications (ISO27001, SOC 2 Type II) and general safeguards (administrative, technical, physical) to prevent unauthorized access, use, modification, disclosure, or destruction. It also directs users to a "Security Policy" for further details.

```
{
  "article_number": 32,
  "article_title": "Security of processing",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy mentions industry certifications (ISO27001, SOC 2 Type II) and general safeguards (administrative, technical, physical) to prevent unauthorized access, use, modification, disclosure, or destruction. It also directs users to a \"Security Policy\" for further details.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 33 — Breach notification to SA

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The policy mentions data security, safeguards, and has a Data Protection Officer, but does not mention breach notification to a supervisory authority or a 72-hour timeframe.

```
{
  "article_number": 33,
  "article_title": "Breach notification to SA",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy mentions data security, safeguards, and has a Data Protection Officer, but does not mention breach notification to a supervisory authority or a 72-hour timeframe.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 34 — Breach communication to data subject

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

```
{
  "article_number": 34,
  "article_title": "Breach communication to data subject",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": null,
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 35 — DPIA

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The provided text does not contain any explicit mention or discussion of Data Protection Impact Assessments (DPIAs) or related concepts required by Article 35 of the GDPR. Therefore, the policy does not materially address the topic.

```
{
  "article_number": 35,
  "article_title": "DPIA",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The provided text does not contain any explicit mention or discussion of Data Protection Impact Assessments (DPIAs) or related concepts required by Article 35 of the GDPR. Therefore, the policy does not materially address the topic.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 37 — DPO designation

Priority: p2 Chapter: Ch.4 – Controller & processor

Severity: warning Status: partial

Score: 44/100

Risk: high

Gaps

- The policy does not state whether the company is a public authority, engages in large-scale monitoring, or processes special categories of data, which are conditions that would necessitate the designation of a Data Protection Officer (DPO) under Article 37 of the GDPR.
- The policy does not provide any contact details for a Data Protection Officer (DPO), which is a requirement under Article 37(7) of the GDPR.

Notes

The provided policy text does not contain sufficient information to determine if a DPO is required by Article 37(1) of the GDPR. Additionally, there is no mention of DPO contact details being published, as required by Article 37(7).

```
{
  "article_number": 37,
  "article_title": "DPO designation",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not state whether the company is a public authority, engages in large-scale monitoring, or processes special categories of data, which are conditions that would necessitate the designation of a Data Protection Officer (DPO) under Article 37 of the GDPR.",
    "The policy does not provide any contact details for a Data Protection Officer (DPO), which is a requirement under Article 37(7) of the GDPR."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The provided policy text does not contain sufficient information to determine if a DPO is required by Article 37(1) of the GDPR. Additionally, there is no mention of DPO contact details being published, as required by Article 37(7).",
  "article_material_used": "text"
}
```

Art. 38 — DPO position

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: warning Status: present (unverified)

Score: 70/100

Notes

The policy mentions the appointment of a Data Protection Officer, which is relevant to Article 38 concerning the DPO position.

```
{
  "article_number": 38,
  "article_title": "DPO position",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy mentions the appointment of a Data Protection Officer, which is relevant to Article 38 concerning the DPO position.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 39 — DPO tasks

Priority: p2 **Chapter:** Ch.4 – Controller & processor

Severity: warning **Status:** partial

Score: 52/100

Risk: high

Gaps

- The company policy does not explicitly state the tasks of the Data Protection Officer (DPO) regarding advising and monitoring compliance with data protection regulations, conducting Data Protection Impact Assessments (DPIAs), or cooperating with supervisory authorities.

Notes

The policy mentions the appointment of a Data Protection Officer to oversee the management of personal information, but it does not detail the specific tasks or responsibilities of the DPO as required by GDPR Article 39. Specifically, there is no mention of the DPO's role in advising the controller/processor, monitoring compliance, involvement in DPIAs, or cooperation with supervisory authorities.

```
{
  "article_number": 39,
  "article_title": "DPO tasks",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The company policy does not explicitly state the tasks of the Data Protection Officer (DPO) regarding advising and monitoring compliance with data protection regulations, conducting Data Protection Impact Assessments (DPIAs), or cooperating with supervisory authorities."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy mentions the appointment of a Data Protection Officer to oversee the management of personal information, but it does not detail the specific tasks or responsibilities of the DPO as required by GDPR Article 39. Specifically, there is no mention of the DPO's role in advising the controller/processor, monitoring compliance, involvement in DPIAs, or cooperation with supervisory authorities.",
  "article_material_used": "text"
}
```

Art. 40 — Codes of conduct

Priority: p3 **Chapter:** Ch.4 – Controller & processor

Severity: critical **Status:** missing

Score: 0/100

Notes

The policy does not mention codes of conduct or adherence to them.

```
{
  "article_number": 40,
  "article_title": "Codes of conduct",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not mention codes of conduct or adherence to them.",
}
```

```

    "status": null,
    "gaps": [],
    "risk": null
  }

```

Art. 42 — Certification

Priority: p3 Chapter: Ch.4 – Controller & processor

Severity: critical Status: missing

Score: 0/100

Notes

The policy does not mention certification at all.

```

{
  "article_number": 42,
  "article_title": "Certification",
  "chapter": "Ch.4 – Controller & processor",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not mention certification at all.",
  "status": null,
  "gaps": [],
  "risk": null
}

```

Art. 44 — General principle for transfers

Priority: p2 Chapter: Ch.5 – Transfers to third countries

Severity: warning Status: partial

Score: 52/100

Risk: high

Gaps

- The policy does not explicitly state that all international transfers of personal data comply with Chapter V mechanisms.

Notes

The policy does not contain explicit statements regarding compliance with Chapter V mechanisms for international data transfers. Therefore, it is not possible to determine compliance based solely on the provided text.

```

{
  "article_number": 44,
  "article_title": "General principle for transfers",
  "chapter": "Ch.5 – Transfers to third countries",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not explicitly state that all international transfers of personal data comply with Chapter V mechanisms."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy does not contain explicit statements regarding compliance with Chapter V mechanisms for international data transfers. Therefore, it is not possible to determine compliance based solely on the provided text.",
  "article_material_used": "text"
}

```

Art. 45 — Adequacy decision transfers

Priority: p2 Chapter: Ch.5 – Transfers to third countries

Severity: warning Status: partial

Score: 52/100

Risk: medium

Gaps

- No mention of adequacy decisions or transfers to third countries.

Notes

The provided policy text does not contain any information regarding adequacy decisions or transfers of personal data to third countries, which is the subject of GDPR Article 45. Therefore, compliance cannot be fully assessed.

```
{
  "article_number": 45,
  "article_title": "Adequacy decision transfers",
  "chapter": "Ch.5 - Transfers to third countries",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "No mention of adequacy decisions or transfers to third countries."
  ],
  "evidence": [],
  "risk": "medium",
  "needs_human_review": false,
  "notes": "The provided policy text does not contain any information regarding adequacy decisions or transfers of personal data to third countries, which is the subject of GDPR Article 45. Therefore, compliance cannot be fully assessed.",
  "article_material_used": "text"
}
```

Art. 46 — Transfers with safeguards

Priority: p3 Chapter: Ch.5 – Transfers to third countries

Severity: warning Status: present (unverified)

Score: 70/100

Notes

The policy mentions EU Commission's Model Contractual Clauses and Standard Contractual Clauses (SCCs) in the context of international data transfers, which aligns with the topic of GDPR Article 46.

```
{
  "article_number": 46,
  "article_title": "Transfers with safeguards",
  "chapter": "Ch.5 - Transfers to third countries",
  "priority": "p3",
  "policy_present": true,
  "implementation_unverified": true,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy mentions EU Commission's Model Contractual Clauses and Standard Contractual Clauses (SCCs) in the context of international data transfers, which aligns with the topic of GDPR Article 46.",
  "status": null,
  "gaps": [],
  "risk": null
}
```

Art. 47 — Binding corporate rules

Priority: p3 Chapter: Ch.5 – Transfers to third countries

Severity: critical Status: missing

Score: 0/100

Notes

The policy does not mention Binding Corporate Rules (BCR) or any related concepts. The agent action describes a verification step for DPA approval, which is not present in the policy.

```
{
  "article_number": 47,
  "article_title": "Binding corporate rules",
  "chapter": "Ch.5 - Transfers to third countries",
  "priority": "p3",
  "policy_present": false,
  "implementation_unverified": false,
  "needs_human_review": true,
  "evidence": [],
  "notes": "The policy does not mention Binding Corporate Rules (BCR) or any related concepts. The agent action describes a verification step for DPA approval, which is not present in the policy.",
  "status": null,
  "gaps": [],
  "risk": null
}
```



```
}
```

Art. 77 — Right to lodge a complaint

Priority: p2 Chapter: Ch.8 – Remedies, liability & penalties

Severity: info Status: pass

Score: 100/100

Risk: low

```
{
  "article_number": 77,
  "article_title": "Right to lodge a complaint",
  "chapter": "Ch.8 – Remedies, liability & penalties",
  "priority": "p2",
  "status": "pass",
  "gaps": [],
  "evidence": [],
  "risk": "low",
  "needs_human_review": false,
  "notes": null,
  "article_material_used": "text"
}
```

Art. 88 — Employment context

Priority: p2 Chapter: Ch.9 – Specific processing situations

Severity: warning Status: partial

Score: 52/100

Risk: high

Gaps

- The policy does not specify rules for the employment context, such as recruitment, performance of the contract of employment, management, planning and organisation of work, equality and diversity in the workplace, health and safety at work, protection of employer's or customer's property, and the termination of the employment relationship.

Notes

The policy lacks specific details regarding the processing of employee data within the employment context.

While it mentions that "Our employees will also have access to data that you knowingly share with us for technical support or to import data into our products or services," this is in the context of providing services to customers, not for internal HR purposes. There is no information related to recruitment, health and safety, or termination processes for employees. Therefore, compliance with Article 88 cannot be fully determined.

```
{
  "article_number": 88,
  "article_title": "Employment context",
  "chapter": "Ch.9 – Specific processing situations",
  "priority": "p2",
  "status": "partial",
  "gaps": [
    "The policy does not specify rules for the employment context, such as recruitment,
performance of the contract of employment, management, planning and organisation of work,
equality and diversity in the workplace, health and safety at work, protection of employer's or
customer's property, and the termination of the employment relationship."
  ],
  "evidence": [],
  "risk": "high",
  "needs_human_review": false,
  "notes": "The policy lacks specific details regarding the processing of employee data within
the employment context. While it mentions that \"Our employees will also have access to data
that you knowingly share with us for technical support or to import data into our products or
services,\" this is in the context of providing services to customers, not for internal HR
purposes. There is no information related to recruitment, health and safety, or termination
processes for employees. Therefore, compliance with Article 88 cannot be fully determined.",
  "article_material_used": "text"
}
```

Appendix — human review queue

```
[
  {
    "kind": "p3_verify",
    "article_number": 8,
    "article_title": "Child's consent",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": [],
    "notes": null
  },
  {
    "kind": "p3_verify",
    "article_number": 10,
    "article_title": "Criminal convictions data",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not mention criminal convictions data or data relating to criminal offenses. It discusses the types of personal data collected, how it is used, and with whom it is shared, but there is no specific mention of Article 10 data."
  },
  {
    "kind": "p3_verify",
    "article_number": 19,
    "article_title": "Notification on rectification/erasure",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not mention notification to recipients in the event of rectification or erasure of data."
  },
  {
    "kind": "p3_verify",
    "article_number": 25,
    "article_title": "Privacy by design and default",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": null
  },
  {
    "kind": "p3_verify",
    "article_number": 26,
    "article_title": "Joint controllers",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not contain any mention of joint controllership or how it is determined or handled."
  },
  {
    "kind": "p3_verify",
    "article_number": 27,
    "article_title": "Representatives (non-EU)",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not contain any information about non-EU representatives or the requirement for a written mandate."
  },
  {
    "kind": "p3_verify",
    "article_number": 32,
    "article_title": "Security of processing",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": [],
    "notes": "The policy mentions industry certifications (ISO27001, SOC 2 Type II) and general safeguards (administrative, technical, physical) to prevent unauthorized access, use, modification, disclosure, or destruction. It also directs users to a \"Security Policy\" for further details."
  },
  {
    "kind": "p3_verify",
    "article_number": 33,
    "article_title": "Breach notification to SA",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
```

```

    "notes": "The policy mentions data security, safeguards, and has a Data Protection Officer, but does not mention breach notification to a supervisory authority or a 72-hour timeframe."
  },
  {
    "kind": "p3_verify",
    "article_number": 34,
    "article_title": "Breach communication to data subject",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": null
  },
  {
    "kind": "p3_verify",
    "article_number": 35,
    "article_title": "DPIA",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The provided text does not contain any explicit mention or discussion of Data Protection Impact Assessments (DPIAs) or related concepts required by Article 35 of the GDPR. Therefore, the policy does not materially address the topic."
  },
  {
    "kind": "p3_verify",
    "article_number": 38,
    "article_title": "DPO position",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": [],
    "notes": "The policy mentions the appointment of a Data Protection Officer, which is relevant to Article 38 concerning the DPO position."
  },
  {
    "kind": "p3_verify",
    "article_number": 40,
    "article_title": "Codes of conduct",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not mention codes of conduct or adherence to them."
  },
  {
    "kind": "p3_verify",
    "article_number": 42,
    "article_title": "Certification",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not mention certification at all."
  },
  {
    "kind": "p3_verify",
    "article_number": 46,
    "article_title": "Transfers with safeguards",
    "policy_present": true,
    "implementation_unverified": true,
    "evidence": [],
    "notes": "The policy mentions EU Commission's Model Contractual Clauses and Standard Contractual Clauses (SCCs) in the context of international data transfers, which aligns with the topic of GDPR Article 46."
  },
  {
    "kind": "p3_verify",
    "article_number": 47,
    "article_title": "Binding corporate rules",
    "policy_present": false,
    "implementation_unverified": false,
    "evidence": [],
    "notes": "The policy does not mention Binding Corporate Rules (BCR) or any related concepts. The agent action describes a verification step for DPA approval, which is not present in the policy."
  }
]

```